2026 金融科技大赛 · 项目答辩

星河虚拟银行 Agent

让对话式金融助手「可拒绝 · 可审计 · 可复核」

本地合成数据教学原型： 13 个业务模块 · 4 类金融业务 · 0 第三方依赖

Agent-API 智能版 + 2026-11-01 安全加固版

汇报信息

时长 10 分钟

14 页正文 + 2 页备用

2026-11-01

全部账户、交易、行情与身份均为虚构样例；不连接真实银行、证券或身份服务。

把「聊天」关进笼子

大模型让「说得像」变容易，也让「做得对」变难。我们做的是后半段。

4
类金融业务
转账 · 理财 · 卡片 · 跨场景计划

16
步资金路径
从一句话到一次可回溯的扣款

18
条安全发现
首轮自评全部逐项处置

162
项自动化测试
加固后 100% 通过

我们不追求「AI 能办多少事」，而是回答一个更难的问题：
当 AI 说「已经帮您转账了」，凭什么相信它没有多扣、没有错扣、没有被骗？

纯 Python 标准库实现 · Windows 免安装运行时 · 断网可跑 · 全部数据合成

对话式金融助手的三道坎

这三件事，靠「换更大的模型」解决不了。

01

意图不可控

同一句话，可能是查询、可能是转账，也可能是骗子在诱导。

自然语言没有 schema，模型输出不可信。

02

授权说不清

用户点了「确认」，他确认的是哪一笔、多少钱、扣哪个账户？

没有摘要绑定，确认就只是一次点击。

03

出错不可追

失败了到底扣没扣？网络超时后重试，会不会扣两次？

资金动作必须幂等，且结果可核验。

结论：金融 Agent 的难点不在「听懂」，而在「听懂之后还敢不敢办、办完能不能查」。

四道闸门：四个维度同时成立才允许资金动作

认证、风险、授权、执行——每一道都由服务端判定，客户端改变不了。

① 认证强度

谁能做

NONE / STANDARD / ENHANCED

渠道由服务端会话决定

升级需一次性安全码

② 操作风险

该不该做

R0 — R4 只升不降

人工审核标记强制 R4

R4 永远不自动执行

③ 用户授权

用户同意了吗

确认短语 + 预览摘要

一次性 nonce，用后作废

两条例外均写死边界

④ 执行与核验

做几次

审计先行 → 单键幂等 → 按键回查

查不到就是 UNKNOWN

绝不重新提交

四者同时满足 → 才允许产生副作用；任意一道不通过，任务停在明确状态上，并如实告诉用户。

六层架构：每层只做一件事

同一个 Agent 内核，两种前端、两条意图通道、九个模拟工具。

① 交互层	**浏览器工作台 • 命令行演示** 聊天、表单、确认按钮、首次收款人核对弹窗
② 接入与会话	**LocalBankServer • BrowserSession** 仅 127.0.0.1 · 精确 Host/Origin/CSRF · 会话 LRU 淘汰
③ 意图理解	**规则解析器 ‖ LLM 规划器** 规则通道默认零联网；模型通道只提类型化操作，参数白名单校验
④ 编排核心	**BankingAgent • BankingWorkflow** 状态机 · 认证 · 风险合并 · 预览确认 · 幂等执行 · 组合计划
⑤ 工具适配	**ToolRegistry → SimulatedBank** 认证 / 风控 / 查询 / 收款解析 / 预览 / 执行 / 状态 / 审核，共 9 个协议
⑥ 数据与审计	**会话内存 + AuditLog** JSONL 追加 · SHA-256 链 · 事件 HMAC 签名 · fsync · 审计先行

一次转账要过七个检查点

以「给张三转账 2888 元」为例：身份核对之前，一分钱都不会动。

1. **输入**
   一句话
   或表单
2. **校验**
   Host/Origin
   CSRF/ 去重
3. **认证**
   服务端渠道
   ENHANCED
4. **识别**
   新收款人?
   暂停任务
5. **核对**
   弹窗确认
   虚构尾号
6. **确认**
   3000 元分界
   直转或确认
7. **执行**
   审计→幂等
   →按键回查

身份核对前 • 不扣款

身份核对只是操作者确认

不查真实身份，不是 KYC ，也不验证账户归属。

3000 元是授权分界

严格小于走小额直转；恰好 3000 必须核对摘要。

结果只以工具回执为准

浏览器不推断成功；查不到状态即 UNKNOWN ，不重试。

认证与风险：两道独立的分级

一个回答「你是谁」，一个回答「这事多危险」。两者都不由客户端决定。

认证等级（谁来证明）

NONE	公开信息	无账户操作
STANDARD	即时通讯渠道	查询可用，资金操作被拦
ENHANCED	APP 安全界面	变更类操作的最低要求
MANUAL	保留枚举	未实现审核员登录

升级只有一条路径：输入页面显示的一次性 6 位安全码（5 分钟有效、用后轮换）。聊天里说「切换到 APP」不会改变认证等级。

认证升级流程

发起资金操作 › 被拦在待认证 › 输入安全码 › 任务自动恢复

风险等级（只升不降）

R0	公开规则	不查账户
R1	余额 / 账单 / 持仓	查询后返回
R2	预算 / 提醒 / 锁卡	摘要确认
R3	转账 /AA/ 投资 / 卡片	先确认再执行
R4	诈骗 / 限额 / 新收款人	只进审核，不执行

有效风险 = max(操作下限，工具评估)； 10000 元或当日累计 20000 元 → R4

确认与幂等：把「一次」做扎实

确认解决「用户同意了什么」，幂等解决「这笔只做一次」。

确认绑定三件事

① 摘要
对预览字段与风险等级做规范化 SHA-256；内容一变，旧确认立即失效。

② 一次性 nonce
24 字节随机串，与任务绑定，确认成功即作废；不由 csrf 推导，无法重放。

③ 有效期
默认 300 秒；渠道变化会作废旧摘要并要求重新认证。

幂等的三层防护

浏览器层 request_id → 请求指纹
同号同内容返回快照，同号不同内容 409

任务层 user+session+request_id
复用任务；载荷变化返回冲突

执行层 idempotency_key
工具复用已记录结果，按同一键回查

两条硬规则：① 审计写不进去，就不执行资金动作；② 结果查不到就报 UNKNOWN，只按原幂等键查询，绝不重新提交。

规则 + 模型：模型提升的是理解，不是权限

模型只能提出「类型化操作」，能不能办由服务端决定。

规则通道（默认）

确定性中文规则

- 关键词 + 正则匹配
- 完全确定，同一输入同一结果
- 零联网、零依赖
- 缺字段就追问，不猜

模型通道（可选）

OpenAI 兼容 Function Calling

- 理解同义表达与上下文指代
- 只用 HTTPS 公网接口
- 工具参数逐字段白名单校验
- 失败就固定文案降级，不换通道硬办

模型不能做的事：不能确认交易、不能提交认证或风险字段、不能使用内部收款人引用、
不能一轮里改两次状态、不能把「暂不执行」办成执行。一句话：它能建议，但不能签字。

我们给自己做了一次安全测评

18 条发现、两个生产阻断项，全部在加固版里处置。

首轮自评： 18 条发现



严重：认证可自证 · 高：确认可旁路、限额可跨会话

14
已修复

4
部分修复（需基础设施）

两个生产阻断项的处理结果：

· 认证可自证 → 改为服务端渠道 + 一次性安全码

· 股票免确认 → 并入统一确认门，未确认不扣款

加固后复测

162 项自动化回归
全部通过，新增 14 项加固用例

29 项 HTTP 黑盒探测
认证 / 确认 / 限额 / 会话 / 响应头全覆盖

0 个未处置的阻断项
剩余 9 条为需要真实基础设施的残余风险

四个动作，四个从「能做」到「做对」

每一项都对应可复现的攻击路径，修复前后都有实测记录。

认证	说一句「切换到 APP 」就能提权并扣款	→	输入页面一次性安全码才升级，用后即失效
确认	股票「一键买入」直接扣 1281.28 元	→	统一走预览 + 确认，未确认余额不变
限额	开三个浏览器各转 9000 ，绕过当日上限	→	进程级共享账本，第三次直接被拦
金额	输入 1e999 元，被截成 999 元还执行了	→	严格整串匹配，非法表达式直接拒绝

四组数字来自同一个测试脚本，可现场复跑；修复没有降低任何业务能力。

能跑、能查、能复现

评审拿到包，双击就能跑；每条结论都能自己验一遍。

零第三方依赖

33 个业务与测试模块全部使用 Python 标准库，供应链面几乎为零。

免安装运行时

Windows 包内置经过校验的 CPython，解压即用，无需管理员权限。

可复现的验收

162 项测试 + 29 项探测脚本随包提供，命令写在验收清单里。

可追溯的交付

交付清单逐个文件 SHA-256，本次核对 102 个文件一致。

配套文档

技术文档 34 页、安全自评报告 26 页、验收清单 14 项加固验收。

演示即证据

所有业务为合成数据，现场演示不会触碰任何真实账户。

```
python -X utf8 -m unittest discover -s tests -v      →      162 tests, OK
python -X utf8 launch_demo.py --web                  →      127.0.0.1  本地演示，断网可用
```

我们明确不做什么，也明确还差什么

把边界讲清楚，比把 Demo 讲漂亮更重要。

明确不宣称

- 不连接真实银行、证券、征信或身份服务
- 不提供真实支付、清算、开户或投资建议
- 没有真实登录、 MFA 、 RBAC 与双人复核
- 不是生产级不可变存储，审计可被有密钥者重算

上生产路线（需要真实基础设施）

P0	**真实身份与会话**	银行身份服务 + MFA + 会话吊销
P0	**权威账户存储**	数据库事务 + 账户维度加锁
P1	**审计可信化**	KMS 签名 + 外部锚定 + 跨进程锁
P2	**容量与供应链**	压测限流 + CI 固定 SHA + 分发签名

我们更愿意把「哪里还不行」写在报告里，而不是在答辩时被问出来。

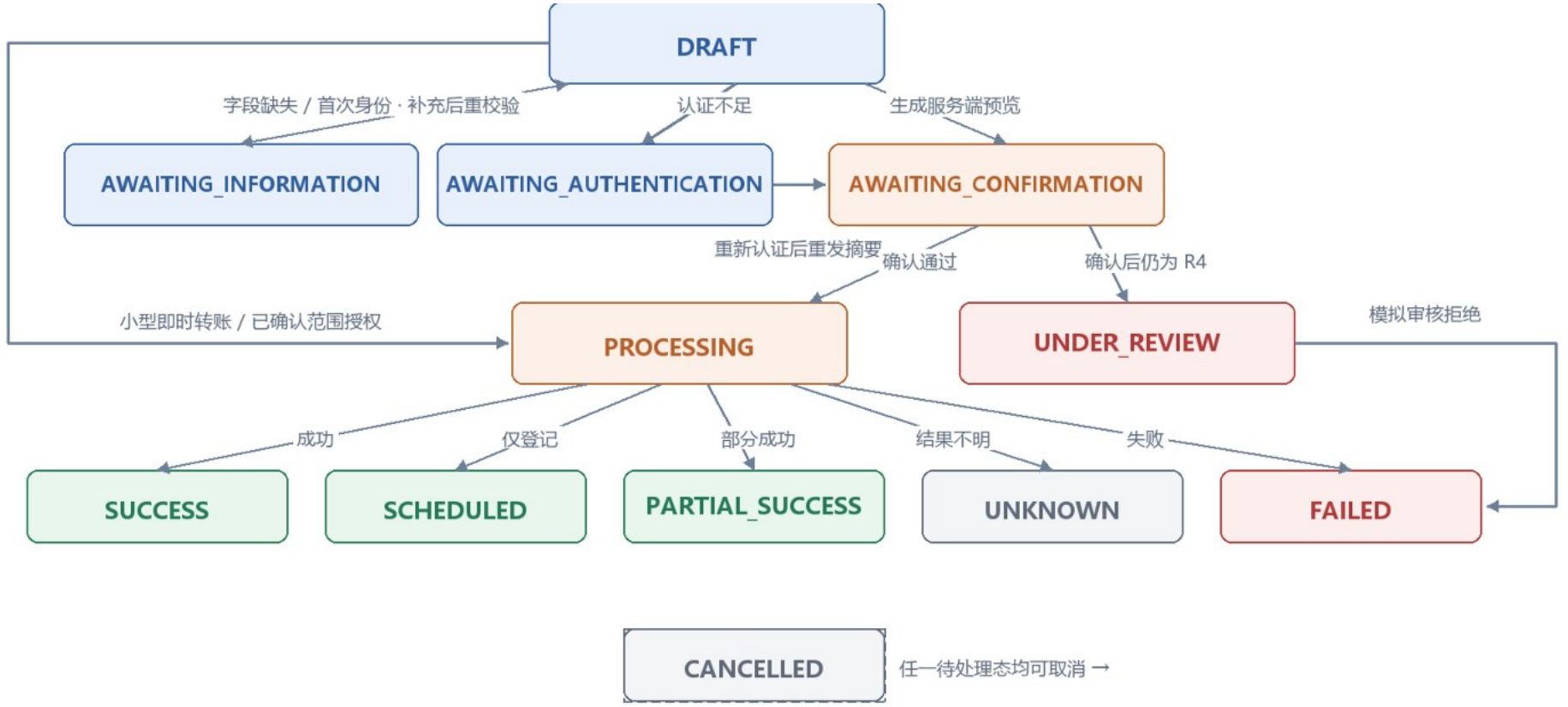
我们做的不是一个「会聊天的银行」，

而是一条「能被检查的资金链路」。

能拒绝、能解释、能回查——这是我们对金融 Agent 的理解。

谢谢各位老师，欢迎提问。

备用一：任务状态机与幂等细节



注：确认有效期 300 秒，过期转 FAILED；渠道切换使旧摘要失效并回到 AWAITING_AUTHENTICATION；UNKNOWN 只按原幂等键查询，不重新提交。
SCHEDULED 表示已登记定时任务，不代表已经扣款；UNDER_REVIEW 不提供自动批准执行的分支。

备用二：测评证据一览

被问到「你们怎么验证的」时使用。

代码审计	13 个业务模块逐文件复核， demo.py 按函数索引分段精读	**18 条发现，全部带文件行号**
自动化回归	162 项用例，含新增 14 项加固用例	**162 通过 / 0 失败**
HTTP 黑盒探测	认证、确认、限额、会话、响应头共 29 组请求	**29 项全部符合预期**
攻击路径复测	首轮 7 条攻击路径逐条重放	**7 条全部被拦截**
交付核对	102 个文件逐个 SHA-256	**0 处不匹配**